RegTech, Compliance, and Anti-Money Laundering

Lecture 11 — LLMs for Regulatory Technology, Compliance & AML

Juan F. Imbet

Paris Dauphine – PSL University

June 20, 2026

Outline

Why Compliance Is the Oldest Friction in Finance

THE BIGGER PICTURE

Long before neural networks, banks employed armies of analysts to read news, cross-reference sanctions lists, and write suspicious activity reports. AI entered an environment *already saturated* with rules — rules not written with AI in mind.

The challenge is not too little guidance — it is too much. A single LLM for adverse media screening must simultaneously satisfy:

- EU AI Act — risk classification & conformity assessment
- MiFID II — algorithmic governance & suitability documentation
- GDPR — automated processing & data-minimisation constraints
- FATF — the risk-based approach to AML/CFT
- SR 11-7 / EBA — model risk management expectations

Each uses different vocabulary, evidence standards, and oversight ownership.

EU AI Act: Four Risk Tiers (Reg. (EU) 2024/1689)

The first comprehensive horizontal AI law. Classifies systems by risk to health, safety, or fundamental rights.

Tier	Examples	Status
Unacceptable	social scoring, biometric ID	Prohibited
High risk	creditworthiness, insurance (Annex III)	Mandatory reqs.
Limited risk	chatbots, emotion recognition	Transparency
Minimal risk	spam filters, recommenders	Unregulated

The critical question for finance: Annex III?

Creditworthiness assessment is *explicitly* listed. Adverse media screening that *determines* credit/insurance/payment access → high-risk. An LLM that merely *summarises* an article for a human analyst → limited / minimal risk.

High-Risk Obligations → Engineering Choices

UNDER THE HOOD

Seven categories of mandatory requirement, each mapping to a concrete build decision.

Requirement	**Engineering implication**
Risk management (lifecycle)	drift monitoring, re-validation
Data governance	representative, proxy-free training data
Technical documentation	ex-post reviewable model cards
Automatic logging	audit-trail infrastructure
Transparency to deployers	instructions for use
Human oversight	analyst review-queue UI
Accuracy / robustness / security	benchmarking + red-teaming

High-Risk Obligations: Who Bears Them?

Provider vs. deployer

Banks using third-party compliance AI are *deployers*, not providers — but still bear obligations (use per instructions, monitor, ensure oversight). **Third-party reliance does not eliminate regulatory liability.**

The seven high-risk obligations on the previous slide attach to the *provider* of the AI system, but a deployer that integrates the system into a credit or onboarding decision inherits a parallel duty of care: verify the system is used within its stated scope, keep humans genuinely in the loop, and log its outputs for ex-post review.

MiFID II, Basel III, and SR 11-7

Framework	What it requires of models
MiFID II	kill switches, pre/post-trade limits, annual self-assessment
Basel III (IRB)	supervisory validation, back-testing, stress testing
SR 11-7	inventory, independent validation, ongoing monitoring

SR 11-7 definition of a model: a quantitative method that applies statistical / economic / mathematical theory to process input data into quantitative estimates. Three pillars: *development*, *validation*, *governance*.

Why LLMs strain SR 11-7

Outputs are probabilistic; internals are not interpretable like a logistic coefficient; behaviour shifts with prompt reformulation. The FSB (2024) flags "challenges for existing MRM frameworks" and urges pre-deployment testing, benchmark monitoring, and adversarial-prompt scenario analysis.

GDPR: Four Provisions That Bind LLM Pipelines

Article	Constraint on LLM compliance systems
Art. 5 (minimisation)	retain only data necessary — tension with RAG c
Art. 9 (special data)	ethnicity, politics, convictions → need legal basis
Art. 17 (erasure)	delete embeddings; can't "un-train" fine-tuned w
Art. 22 (auto. decisions)	right to human review of solely-automated decisi

Art. 22 in practice

A neobank LLM scores *A. Petrov* at 0.87 (high risk) from articles about a *phonetically similar* name in an Eastern-European fraud case, and auto-declines onboarding. Art. 22 grants Petrov the right to human review, to state his view, and to contest. "Our AI said so" is *not* a sufficient explanation — the pipeline must log which articles, passages, and risk factors drove the score.

The Scale of the Problem

THE BIGGER PICTURE

Money laundering moves criminal proceeds through the financial system to obscure their origin. FATF estimates **2–5% of global GDP** (∼\$800bn–\$2tn) is laundered annually — yet only a very small fraction of illicit flows is ever seized or frozen.

Why LLMs, why now? The explosion of sources — news, watchlists, beneficial-ownership registries, court filings, social media — has outpaced human analytical capacity, while regulators expect *comprehensive* monitoring. The gap between obligation and capability is where LLMs add value.

This section

False-positive crisis → agentic screening → RAG architecture → a quantitative Adverse Media Index.

The False-Positive Crisis in Keyword Screening

The dominant paradigm (20 years): match name + DOB + nationality against a watchlist; flag any fuzzy match (Jaro–Winkler, Soundex) above a threshold.

UNDER THE HOOD

Let $\mathcal{P}$ = true matches, $\mathcal{N}$ = true negatives, $\hat{P}$ = flagged set.

$$\mathrm{FPR} = \frac{|\hat{P} \cap \mathcal{N}|}{|\mathcal{N}|}, \qquad \mathrm{PPV} = \frac{|\hat{P} \cap \mathcal{P}|}{|\hat{P}|}.$$

In production, AML screening runs at **FPR 95–99%** — fewer than 1 in 20 alerts is a genuine match.

The False-Positive Crisis: Why It Compounds

The cascade

Alert noise trains staff to treat *all* alerts as noise → genuine matches cleared without scrutiny. Banks are fined both for *missing* laundering and (paradoxically) for generating *excessive low-quality SARs*.

Key insight: a name match in isolation is not evidence. What matters is whether the *contextual* evidence is consistent with a launderer's profile — exactly what LLMs assess and keyword matching cannot.

Agentic LLM Systems for Adverse Media Screening

Rather than an analyst querying a database, an **agent** is given a subject and runs a five-step loop:

1. **Query formulation** — generate searches, incl. local-language variants
2. **Document retrieval** — top-k articles, filtered by date + source tier
3. **Relevance assessment** — same individual? material? credible source?
4. **Evidence extraction** — offence type, jurisdiction, date, alleged vs. convicted
5. **Risk scoring** — structured tier (low/med/high/critical) + cited evidence

"Carlos Fernandez-Gutierrez, b. 1971, MX"

Agent searches EN + ES ("corruption", "money laundering", firm name), reads top-k articles, disambiguates the individual, extracts structured offence evidence, and emits an actionable risk report — **minutes, not hours**.

Design choices: tool selection, memory across steps, and error-handling for common name collisions. ReAct loop → Lecture 4

RAG-Based Adverse Media Pipeline: Five Components

UNDER THE HOOD

Ingestion → vector store → retriever → reader/ranker → formatter.

Component	**Role**
Ingestion	chunk 200–400 tok (overlap), embed, store + metadata
Vector store	dense embeddings *and* BM25; incremental + deletable
Retriever	hybrid search; expand query with alias / transliterations
Reader / ranker	cross-encoder: disambiguate entity + classify relevance
Formatter	grammar-constrained JSON: tier, evidence, offences

Production constraints

Real-time onboarding: full pipeline <30s (pre-built indices, cached embeddings). Batch re-screening: latency relaxed, but throughput must scale to *millions of records/day*.

Hybrid Retrieval via Reciprocal Rank Fusion

Dense (semantic) and sparse (BM25, exact terms) are fused without learned weights:

$$\mathrm{RRF}(d) = \sum_{r \in R} \frac{1}{\kappa + \mathrm{rank}_r(d)}, \qquad \kappa = 60.$$

Documents missed by a ranker get $\mathrm{rank} = \infty$.

Why fusion is robust

A passage ranked highly by *both* retrievers is promoted *above* one that any single retriever ranks first. RRF rewards cross-signal agreement — the property that makes hybrid retrieval beat either modality alone on legal / news documents.

Worked numerically in the practical session (`gen_rrf_fusion.py` / `demo.ipynb`).

The Adverse Media Index (AMI): Text $\to$ Calibrated Score

A binary low/high label is insufficient. We want a continuous, comparable, trackable score.

UNDER THE HOOD

For documents $D = \{d_1, \ldots, d_n\}$ retrieved for subject s, with relevance r_i, credibility c_i, recency $t_i = e^{-\lambda(T - T_i)}$, and offence indicators $\mathbf{e}_i \in \{0,1\}^K$:

$$\mathrm{AMI}(s) = \sigma\left(\alpha + \sum_{i=1}^{n} r_i\, c_i\, t_i\, \mathbf{w}^\top \mathbf{e}_i\right) \in [0,1].$$

$\mathbf{w}$ = offence-severity weights (terrorism financing $\gg$ minor violation); λ = temporal decay (recency vs. history).

- $\mathbf{w}$ calibrated by logistic regression on "subject later a true positive in an enforcement action".
- Output is a probability $\to$ feeds the bank's risk-based customer rating, combined with transaction monitoring + KYC.

Entity Resolution: The Central Technical Challenge

THE BIGGER PICTURE

KYC and sanctions screening reduce to one hard problem: do two imperfect, multilingual, sparse records refer to the *same* real-world entity?

Why it is hard: transliteration variance ("Muammar Gaddafi" has dozens of renderings), name changes (maiden/married/patronymic), watchlist errors, and common-name collisions in large populations.

Entity Resolution: Pipeline and Threshold

UNDER THE HOOD

Entity resolution as *pair classification*: given records x_1, x_2, produce a calibrated $P(\hat{y} = 1 \mid x_1, x_2)$. **Two-stage pipeline:** fast ANN blocking ($O(n^2) \to O(nk)$) then a precise cross-encoder / LLM scorer — mirroring the retriever–ranker pattern.

Threshold asymmetry

For sanctions, set the threshold for *near-100% recall*: a missed true hit costs far more than a false-positive review. LLMs add value by learning transliteration implicitly and resolving ambiguity from auxiliary context.

PEP Screening and Beneficial Ownership

Politically Exposed Persons

- Heads of state, senior officials — *plus* family & close associates (FaMCAs).
- FATF requires enhanced due diligence: source-of-wealth, senior approval.
- Universe is large & changing; commercial DBs are costly, patchy in lower-income jurisdictions.
- LLMs read Wikipedia / gov sites / news → self-updating PEP registry; relation extraction finds FaMCAs.

Beneficial Ownership

- Shells, trusts, nominees hide the ultimate beneficial owner (UBO).
- FATF Rec. 24 + Corporate Transparency Act require registries — but data is scattered.
- LLM extracts owners + stakes → directed ownership graph → traverse to UBO.

Meridian Capital Holdings (UK)

UK PSC → Luxembourg entity → BVI company (no public registry). LLM builds the graph, flags the chain terminates in two opacity jurisdictions, cross-refs adverse media — hours of analyst work compressed to minutes.

Reporting Shares a Common Structure

THE BIGGER PICTURE

A large bank files *hundreds of thousands* of regulatory reports a year. Despite apparent heterogeneity, all share one shape: **extract** quantitative data → **classify** into a taxonomy → **generate** explanatory prose. Each step suits a language model.

Report	Core LLM task	Key risk
XBRL filing	taxonomy concept tagging	20k+ labels, sparsity
SAR	narrative drafting	factual error misleads LE
Stress test	narrative from numbers	numeric hallucination

Across all three: LLM produces *drafts*; human review + automated fact-checking are non-negotiable.

XBRL Tagging as Retrieval, Not Classification

The eXtensible Business Reporting Language is a standardised machine-readable taxonomy (SEC since 2009; ESEF / iXBRL in the EU). Core operation: *tag* each line item with the correct concept.

UNDER THE HOOD

The US GAAP taxonomy has **20,000+ elements** $\Rightarrow$ flat classification fails (label sparsity). Frame it as retrieval + LLM verification:

$$\hat{c}^* = \arg\max_{c \in \mathcal{C}} \Big[\lambda \cos(\mathbf{v}_{\text{item}}, \mathbf{v}_c) + (1-\lambda) P_{\text{LLM}}(c \mid \text{item}, \text{context}) \Big].$$

λ interpolates embedding similarity vs. the LLM posterior; cross-validate on labelled historical filings.

Ambiguous items ("other comprehensive income") + annual taxonomy changes make manual tagging error-prone.

SAR Drafting and Stress-Test Narratives

SAR drafting

- Filed with FinCEN / NCA / TRACFIN on suspicious activity.
- A skilled analyst spends **2–4 hours** per complex SAR.
- LLM drafts the narrative → analyst reviews / validates / supplements.
- A SAR mischaracterising activity misleads law enforcement → liability. Human review *non-negotiable*; flag weak-evidence passages.

Stress-test narratives

- Supervisory submissions run to *hundreds of pages* of prose.
- Quantitative results → template-constrained LLM commentary.
- RAG-ground in prior submissions for consistency.
- Stating "ratio fell 3pp" when output says 2.7pp is a *material* error → post-hoc fact-check pass.

EU AI Act & degree of automation

An LLM that *assists* (pre-populates a template for human review) → limited-risk. An LLM that *files* a SAR autonomously → almost certainly high-risk (full conformity assessment). Compliant designs adopt the former.

Governance Is as Important as the Model

THE BIGGER PICTURE

Compliance functions are governance structures, not just technical systems. A technically excellent system with weak oversight *fails* regulatory review; a modest system with strong governance may *pass*.

Explainability serves two distinct purposes:

Purpose	**Explanation must be...**
Regulatory (GDPR 22, FCRA)	lay-intelligible, actionable, top factors
Internal governance	precise, reproducible, validation-complete

Three techniques (combine for high-stakes decisions):

- **Retrieval transparency** — show top-3 grounding passages + scores
- **Chain-of-thought rationale** — stored, auditable reasoning trace
- **Post-hoc attribution** — SHAP on risk-tier classifier; attention weights are only a *rough* guide, not standalone explanations

Human-in-the-Loop: Designing Against Automation Bias

The failure mode

Poor HITL exhibits *automation bias*: reviewers rubber-stamp the model, especially with large queues, short review time, and discouraged overrides — oversight in form, not substance.

Four design dimensions:

- **Task decomposition —** give the human a task they do *better* than the model (geopolitical context, disambiguation, escalation calls)
- **Uncertainty communication —** surface low-confidence items
- **Override facilitation + feedback —** log override reasons; feed back into monitoring (systematic divergence $\Rightarrow$ drift)
- **Queue design —** order by risk severity $\times$ model confidence; bulk-clear confident low-risk cases with spot checks

Model Risk Management for LLM Compliance Systems

UNDER THE HOOD

SR 11-7's three pillars, extended for LLMs.

Development: document conceptual soundness — the model, why retrieval-generation fits, scope/limits (languages, sources, entities), and *when not to use it*.

Validation (by an independent function):

- Benchmark: precision / recall / F1 on labelled historical cases
- Adversarial: prompt injection, name-variation & paraphrase evasion
- Calibration, bias auditing (across nationalities / name types), robustness

Model Risk Management: Governance & Monitoring

Governance: model-inventory entry, change management (re-validate after LLM / corpus updates), monitoring dashboard with alert thresholds, incident response.

Deployed example thresholds

Precision / recall tracked weekly on 200 senior-reviewed cases. **Precision** $<$**60%** or **recall** $<$**95%** $\Rightarrow$ automatic alert + root-cause review within 5 business days. Every decision (docs, output, reviewer choice) retained **7 years** in a tamper-evident log.

Lecture 11 Summary: Five Takeaways

1. **Frameworks overlap.** EU AI Act, MiFID II, Basel III, SR 11-7, GDPR — map each application to the right tier; many compliance tools are high-risk. GDPR Art. 22 demands explanation + human review.
2. **LLMs break the false-positive crisis** (FPR >95%) by scoring *contextual* consistency — the Adverse Media Index turns text into a calibrated $[0, 1]$ risk score.
3. **RAG is the architecture of choice** — hybrid BM25 + dense + RRF, cross-encoder reader. Powers adverse media, entity resolution, PEP, UBO.
4. **Reporting is automatable with verification** — XBRL, SAR, stress narratives as drafts + automated fact-checking against source data.
5. **Governance $\approx$ technology.** HITL against automation bias, SR 11-7 adapted to LLMs, layered explainability.

Next

Practical 11 — RRF by hand, an Adverse Media Index in Python, and a governance design clinic.

Appendix

RegTech & AML — Extended Material

Extra / optional material — beyond the core lecture.

Appendix: RAG Pipeline Dataflow

1. **Feeds** — news, court filings, press releases (continuous).
2. **Ingestion** — chunk + embed (200–400 tok, overlap).
3. **Vector store** — dense + BM25, metadata (URL, date, source tier, entities); incremental updates + selective deletion (GDPR 17).
4. **Retriever** — subject query (+ alias variants) $\rightarrow$ hybrid + RRF $\rightarrow$ top-k.
5. **Reader / ranker** — cross-encoder reranking scores each passage against the query with full cross-attention (higher quality than the bi-encoder, higher latency).
6. **Output formatter** — grammar-constrained decoding $\Rightarrow$ always-parseable JSON (no brittle parsing downstream).

Metadata fields are critical: they enable post-retrieval filtering that reduces the LLM's ranking burden.

Appendix: AMI Hyperparameters & Calibration

$$\mathrm{AMI}(s) = \sigma\left(\alpha + \sum_{i=1}^{n} r_i\, c_i\, t_i\, \mathbf{w}^\top \mathbf{e}_i\right), \qquad t_i = e^{-\lambda(T - T_i)}.$$

- $\mathbf{w} \in \mathbb{R}^K$ — offence-severity weights; estimate by logistic regression on confirmed enforcement outcomes.
- $\lambda > 0$ — decay rate (e.g. 0.01/day). Aggressive decay emphasises recency; slow decay keeps historical evidence. Rehabilitated / acquitted subjects motivate decay.
- α — baseline intercept; σ maps to a probability of genuine AML risk, integrable into the customer risk rating.

Appendix: Traditional Entity-Resolution Toolkit

Before (and alongside) LLMs:

- **String distance** — edit distance, Jaro–Winkler.
- **Phonetic normalisation** — Soundex, Metaphone, Double Metaphone (non-English names).
- **Blocking** — compare only records sharing first-two characters to bound the comparison space.

LLM advantages: (1) *implicit* transliteration learned from multilingual corpora — generalises to scripts with no hand-coded rules; (2) *context* resolves ambiguity ("Carlos Salinas" vs. "Carlos Salinas de Gortari, former Mexican president"). Recommended reading: the Fellegi–Sunter probabilistic record-linkage model and transformer-based blocking/matching.

Appendix: Key References

- EU AI Act — Reg. (EU) 2024/1689; FSB (2024) AI in financial services.
- SR 11-7 — Fed / OCC model risk management guidance (2011).
- FATF (2021) AI in AML/CFT; FinCEN AML guidance.
- Lewis et al. (2020) RAG; Cormack et al. (2009) reciprocal rank fusion; Gao et al. (2024) RAG survey; Reimers & Gurevych (2019) cross-encoders.
- Lundberg & Lee (2017) SHAP; Wei et al. (2022) chain-of-thought.
- Lin et al. (2025) RiskTagger — LLM agent annotating crypto ML behaviours.

- Cross-refs: Lec. 4 (agents / ReAct), Lec. 6 (credit-risk GDPR & SHAP), Lec. 12 (XAI).